

1. INTRODUÇÃO

No cenário corporativo contemporâneo, a integridade, a confidencialidade e a disponibilidade dos dados são pilares críticos para a continuidade dos negócios. A rápida evolução das ameaças cibernéticas exige que profissionais de tecnologia compreendam não apenas as camadas superiores de aplicação, mas também como os dados transitam pela infraestrutura física e lógica de rede.

Este relatório técnico aborda os resultados e fundamentos da Parte 1 do Projeto Semestral Interdisciplinar "Conexões Seguras". O escopo deste trabalho compreende a análise de vulnerabilidades em Camada 2 e 3 (através de *Sniffing*), os mecanismos de defesa em Camada de Transporte (Protocolo TLS/HTTPS), a segurança na gestão de sessões em Camada de Aplicação e, por fim, o isolamento de tráfego por meio de Redes Privadas Virtuais (VPNs). Cada módulo combina fundamentação teórica com Provas de Conceito (PoCs) validadas e indexadas no ambiente de documentação oficial.

2. MÓDULO 1: SNIFFING E INTERCEPTAÇÃO (CAMADA 2 E 3)

2.1 Fundamentação Teórica: O Modo Promíscuo e a NIC

Em uma operação padrão de rede — conhecida tecnicamente como Modo Não-Promíscuo —, o Controlador de Interface de Rede (NIC - *Network Interface Card*) atua como um filtro baseado em hardware operando na Camada 2 (Enlace) do modelo de referência OSI. Ao monitorar os quadros de dados que trafegam pelo meio físico compartilhado (barramentos de cobre, fibra ótica ou ondas de radiofrequência), a NIC examina exclusivamente o cabeçalho do quadro em busca do **Endereço MAC de destino**. Se o endereço físico gravado no quadro não corresponder ao MAC address da própria placa, e não se enquadrar em um endereço de difusão (*broadcast* generalizado como FF:FF:FF:FF:FF:FF) ou multidifusão (*multicast*) autorizado, o hardware descarta o quadro de forma imediata. Este comportamento mitiga o desperdício de ciclos de processamento por parte da Unidade Central de Processamento (CPU) do sistema operacional hóspede com tráfego irrelevante.

Por outro lado, quando a NIC é instruída pelo sistema operacional a operar em **Modo Promíscuo**, esse mecanismo interno de filtragem por hardware é completamente desativado. A partir deste instante, a interface de rede aceita e encaminha para a pilha de protocolos de software do sistema operacional **todo e qualquer quadro que**

transite pelo meio físico, independentemente do Endereço MAC de destino contido no cabeçalho.

Em auditorias e análises legítimas de infraestrutura, o modo promíscuo viabiliza o mapeamento de gargalos e diagnóstico de anomalias. Contudo, em cenários de ameaça interna, caso um ator malicioso obtenha acesso lógico a um segmento da rede local (LAN), ele utilizará o modo promíscuo para realizar o *Sniffing*, capturando dados confidenciais pertencentes a outros ativos de rede caso estes trafeguem sem criptografia estrutural.

2.2 Demonstração Prática (PoC)

- **Ferramenta Utilizada:** Wireshark v4.x (Analisador de Protocolos Open-Source).
- **Passo a Passo:** 1. O software Wireshark foi inicializado com privilégios de superusuário (Administrador/sudo) para permitir chamadas de sistema de baixo nível na interface de rede. 2. Acedeu-se ao menu *Capture -> Options*, onde validou-se a ativação global da diretiva "*Enable promiscuous mode on all interfaces*". 3. Selecionou-se a interface de rede ativa conectada ao segmento de testes e disparou-se a captura em tempo real. 4. Através de um terminal isolado, gerou-se tráfego de infraestrutura executando a ferramenta utilitária ping direcionada ao endereço IP do gateway da rede local. 5. A captura foi interrompida e aplicou-se o filtro de exibição de protocolo `icmp` na barra de ferramentas superior do analisador.
- **Resultado:** O Wireshark registrou com sucesso múltiplos pacotes do protocolo ICMP (*Internet Control Message Protocol*), evidenciando requisições (*Echo Request*) e respostas (*Echo Reply*) correspondentes ao tráfego simulado, capturando dados que trafegavam na mídia local.
- **Explicação Técnica:** O êxito da captura de pacotes cujos fluxos de tráfego envolveram nós distintos demonstra o acionamento do Modo Promíscuo. Ao contornar o filtro da NIC, os buffers do Wireshark leram dados brutos diretamente da camada física, comprovando que dados expostos na rede local em formato de texto limpo são vulneráveis à interceptação passiva.

3. MÓDULO 2: CRIPTOGRAFIA E HANDSHAKE (A BASE DO TLS)

3.1 Fundamentação Teórica: A Inviabilidade Assimétrica Global e a Abordagem Híbrida

O protocolo HTTPS (que opera sobre o TLS - *Transport Layer Security*) implementa uma arquitetura de **Criptografia Híbrida** para responder a um desafio fundamental da segurança: conciliar máxima proteção com alta performance computacional.

Se o HTTPS utilizasse **exclusivamente criptografia assimétrica** (par de chaves pública e privada com algoritmos como RSA ou ECC) para cifrar todo o tráfego de dados de uma sessão, a viabilidade operacional de serviços web seria anulada. Algoritmos assimétricos são fundamentados em problemas matemáticos complexos de altíssimo custo computacional, tais como a fatoração de inteiros estendidos ou logaritmos discretos em curvas elípticas. Cifrar e decifrar fluxos contínuos de gigabytes de dados (páginas HTML, folhas de estilo, scripts, imagens e vídeos) sob criptografia assimétrica geraria um consumo massivo de processamento (CPU), resultando em alta latência para o cliente e rápida exaustão de hardware nos servidores centrais.

A arquitetura híbrida soluciona este problema ao fragmentar a conexão segura em duas fases distintas e complementares:

1. **Fase Assimétrica (Handshake / Troca de Chaves):** No início da sessão, o cliente solicita a chave pública do servidor. O servidor responde enviando o seu Certificado Digital válido (X.509) que hospeda a sua chave pública. O cliente, de forma independente, gera um segredo pseudo-aleatório efêmero, denominado **Chave de Sessão**. Utilizando a chave pública do servidor, o cliente cifra essa chave de sessão e transmite o bloco criptografado de volta ao servidor. O servidor, sendo o único detentor da chave privada simétrica correspondente, decifra a mensagem e extrai a chave de sessão. Esta fase assegura a confidencialidade na troca de chaves sem a necessidade de um canal previamente seguro.
2. **Fase Simétrica (Transferência de Dados em Larga Escala):** Uma vez que tanto o cliente quanto o servidor possuem cópias idênticas da Chave de Sessão, o canal assimétrico é encerrado. Toda a comunicação subsequente é inteiramente cifrada por algoritmos de criptografia simétrica de alta performance, predominantemente o **AES (Advanced Encryption Standard)**. Os algoritmos simétricos operam por meio de transposições, permutações e substituições de bits estruturadas em blocos, exigindo uma fração irrisória do

poder de processamento do hardware, o que garante uma transferência de dados veloz e segura em larga escala.

3.2 Demonstração Prática (PoC)

- **Ferramenta Utilizada:** DevTools do navegador web (Google Chrome / Engine Blink).
- **Passo a Passo:** 1. Acedeu-se ao domínio de produção seguro <https://ead.sp.senai.br> 2. Disparou-se o console de ferramentas do desenvolvedor através da tecla de atalho F12. 3. Navegou-se até o painel expandido de auditoria denominado *Security* (Segurança). 4. Inspeccionou-se a secção de metadados da conexão ativa sob o rótulo *Connection*.
- **Resultado:** O painel reportou explicitamente os parâmetros criptográficos negociados: uma suíte de cifragem operando sob o protocolo **TLS 1.3**, utilizando o algoritmo **ECDHE_RSA** para a troca assimétrica de chaves e a cifra **AES_128_GCM** para a segurança simétrica dos dados.
- **Explicação Técnico-Prática:** A saída gerada pelo DevTools válida em ambiente de produção a teoria da criptografia híbrida. O termo ECDHE_RSA comprova a execução da fase assimétrica para concordância de chaves via curvas elípticas, enquanto a especificação AES_128_GCM atesta que a camada de dados simétrica está em execução ativa, blindando o tráfego contra sniffers locais de forma eficiente e otimizada.

4. MÓDULO 3: SEGURANÇA NA CAMADA DE APLICAÇÃO (DESENVOLVIMENTO)

4.1 Gestão de Sessão e Cookies: Definição, Riscos e Preocupações do Desenvolvedor

Dado que o protocolo base da Web (HTTP) opera de forma nativa sob um modelo *stateless* (sem retenção de estado), ele é incapaz de associar requisições isoladas vindas de um mesmo utilizador. Para estabelecer persistência, as arquiteturas modernas empregam o mecanismo de **Cookie SessionID**. Após a validação das credenciais de autenticação (usuário e senha) no servidor, a aplicação gera uma string alfanumérica única, com alto índice de entropia, chamada *SessionID* (ID de Sessão). Esse token é devolvido ao cliente através do cabeçalho de resposta HTTP Set-Cookie e armazenado localmente no navegador. Em todas as interações seguintes, o navegador anexa de forma automática esse cookie no cabeçalho das requisições, permitindo ao servidor identificar o estado de autenticação do cliente.

Na posição de pessoa desenvolvedora de software, a principal preocupação reside no facto de o *SessionID* possuir equivalência direta com as credenciais de autenticação do utilizador. Se um vetor de ataque comprometer ou extrair esse token, o invasor conseguirá executar com sucesso o ataque de **Session Hijacking (Sequestro de Sessão)**. O atacante injeta o cookie roubado na sua própria sessão de navegação, assumindo a identidade da vítima perante o servidor e ignorando completamente mecanismos de autenticação de dois fatores ou senhas complexas.

Portanto, o ciclo de vida do desenvolvimento seguro exige que o desenvolvedor implemente salvaguardas rigorosas:

- **Entropia Criptográfica:** Garantir que o ID seja gerado por geradores de números pseudo-aleatórios criptograficamente seguros (CSPRNG), impedindo ataques de predição de tokens.
- **A Flag HttpOnly:** Diretiva essencial que instrui o navegador a bloquear qualquer acesso ao cookie por meio de APIs de script locais (como o objeto JavaScript `document.cookie`). Isso anula o risco de roubo de sessão através de vulnerabilidades de injeção de código do tipo *Cross-Site Scripting (XSS)*.
- **A Flag SameSite:** Configurada adequadamente para restringir o envio automático de cookies em requisições de origens cruzadas, mitigando o risco de ataques de falsificação de solicitações entre sites (*Cross-Site Request Forgery - CSRF*).

4.2 O Papel do HTTPS na Proteção de Cookies e o Cenário Inseguro (Apenas HTTP)

O protocolo HTTPS desempenha um papel crítico na manutenção do sigilo dos identificadores de sessão durante a fase de transporte pela rede. Ao trafegar encapsulado pelo túnel TLS, todo o cabeçalho HTTP de requisição — incluindo a linha reservada aos cookies — é completamente cifrado antes de deixar o host de origem. Isso garante que os dados trafeguem de ponta a ponta em formato de texto cifrado ilegível.

Caso a aplicação web opere **exclusivamente sob o protocolo HTTP convencional**, ocorre uma falha estrutural grave: todos os dados trafegam pela rede em formato de texto limpo (*plain text*). Se um atacante estiver monitorando o tráfego local em modo promíscuo (conforme demonstrado na PoC do Módulo 1), ele conseguirá interceptar os pacotes e ler de forma direta o cabeçalho Cookie: `SessionID=aF83jK9...` utilizando um sniffer de pacotes.

Para evitar o vazamento accidental de tokens em conexões que alternam dinamicamente entre áreas seguras e inseguras, os desenvolvedores devem

obrigatoriamente associar a flag **Secure** aos cookies de sessão. Essa diretiva restringe o comportamento do navegador, proibindo terminantemente a transmissão do cookie se a requisição não for realizada sob uma ligação HTTPS segura.

4.3 Demonstração Prática (PoC)

- **Ferramenta Utilizada:** Painel de Armazenamento das Ferramentas de Desenvolvedor (DevTools).
- **Passo a Passo:** 1. Acedeu-se à plataforma web autenticada do GitHub. 2. Executou-se a abertura do DevTools (F12) e navegou-se até à aba de infraestrutura de dados **Application** (Aplicativo). 3. No menu hierárquico à esquerda, expandiu-se o nó *Cookies* e selecionou-se a URL do domínio avaliado. 4. Analisou-se a matriz de propriedades dos cookies ativos focado nos tokens de autenticação.
- **Resultado:** A tabela de cookies evidenciou que os principais identificadores de sessão possuíam as colunas marcadas como ativas para as flags **HttpOnly** e **Secure**.
- **Explicação Técnica:** A presença visual das flags ativas comprova o alinhamento da aplicação com as boas práticas de desenvolvimento de software seguro. A validação do *HttpOnly* confirma que o token de sessão está protegido contra roubos via vetores XSS baseados em JavaScript, enquanto o marcador *Secure* assegura que o identificador jamais transitará por canais HTTP inseguros, mitigando a vulnerabilidade de sniffing de credenciais.

5. MÓDULO 4: VPN (VIRTUAL PRIVATE NETWORK)

5.1 Mecanismos de Tunelamento, Confidencialidade e Integridade em Redes Públicas

Uma VPN (*Virtual Private Network* - Rede Privada Virtual) é uma arquitetura de rede projetada para estabelecer uma interconexão lógica e segura entre redes privadas ou hosts remotos utilizando como meio de transporte uma infraestrutura de rede pública inerentemente insegura, como a Internet. A sua finalidade corporativa é estender o perímetro de segurança da organização, permitindo que utilizadores externos acessem a recursos internos mantendo os níveis de segurança de um terminal local conectado fisicamente à rede interna.

O fundamento técnico de uma VPN assenta no conceito de **Tunelamento**. O tunelamento é o processo de encapsulamento estruturado de pacotes, onde um pacote de dados completo gerado na rede interna privada (incluindo os endereços IP lógicos corporativos e a carga de dados da aplicação) é tratado como dados puros e

inteiramente inserido dentro do campo de carga útil (*payload*) de um novo pacote de rede externo. Esse novo pacote recebe um cabeçalho de transporte contendo endereços IP públicos e roteáveis, permitindo o seu tráfego através dos roteadores da Internet pública.

Para blindar esse canal virtual contra as ameaças de interceptação mapeadas nos módulos anteriores, as VPNs operam sob rigorosos pilares criptográficos:

- **Confidencialidade:** O pacote de dados original interno é submetido a algoritmos de criptografia simétrica de nível militar (tipicamente AES-256 ou ChaCha20) antes de ser encapsulado pelo pacote de transporte externo. Desta forma, mesmo que ocorra a interceptação de pacotes em trânsito por atores operando sniffers na internet pública, o conteúdo capturado será totalmente incompreensível sem a respectiva chave de decifragem simétrica.
- **Integridade:** Para garantir que os dados não sofram manipulação ou corrupção durante o trânsito pelo canal público, são aplicados códigos de autenticação de mensagens baseados em hash (HMAC) ou assinaturas criptográficas em cada pacote enviado. O host de destino recalcula matematicamente o hash do pacote ao recebê-lo; caso seja detetada qualquer divergência de bits provocada por falha de transmissão ou tentativa de injeção maliciosa, o pacote é imediatamente descartado.

5.2 Análise Comparativa dos Protocolos Corporativos: OpenVPN vs. IPsec

A arquitetura de segurança de uma rede privada virtual é diretamente influenciada pelo protocolo de comunicação adotado na camada de transporte ou de rede. Abaixo apresenta-se uma análise técnico-comparativa de duas das soluções mais robustas implementadas no mercado:

OpenVPN

- **Camada de Operação (Modelo OSI):** Atua predominantemente na **Camada 4 (Transporte)** do modelo de referência, sendo capaz de encapsular dados tanto sobre o protocolo UDP (priorizando baixa latência e velocidade) quanto sobre o TCP (garantindo o controle de fluxo e retransmissão de pacotes).
- **Características de Segurança:** O OpenVPN utiliza extensivamente a suite criptográfica da biblioteca OpenSSL para realizar os processos de autenticação e cifragem. Ele herda nativamente os mecanismos de segurança estáveis do protocolo TLS (discutidos no Módulo 2), suportando cifras modernas como o AES-GCM. Por operar na camada de transporte, o OpenVPN destaca-se pela sua elevada flexibilidade operacional, facilidade de implementação através de

portas customizadas (como a porta padrão UDP 1194) e capacidade técnica avançada para contornar bloqueios estritos em Firewalls corporativos e regras rígidas de tradução de endereços de rede (NAT).

IPsec (Internet Protocol Security)

- **Camada de Operação (Modelo OSI):** Opera de forma nativa e profunda na **Camada 3 (Rede)** do modelo OSI, protegendo de forma agnóstica qualquer tráfego gerado pelas camadas superiores, independentemente da aplicação ou do protocolo de transporte subjacente.
- **Características de Segurança:** O IPsec não é um protocolo isolado, mas sim uma suite de padrões de segurança estruturada em torno de dois subcabeçalhos principais: o AH (*Authentication Header*), que provê integridade e autenticação robusta da origem do pacote, e o ESP (*Encapsulating Security Payload*), encarregue de garantir a confidencialidade integral através da cifragem estrutural do pacote de dados. Devido à sua integração direta na camada de rede, o IPsec apresenta alto desempenho computacional, sendo frequentemente processado diretamente por módulos de hardware dedicados (ASICs) em roteadores de borda e firewalls. É considerado o padrão ouro da indústria para conexões estáveis e permanentes do tipo *Site-to-Site* (interconexão de filiais e datacenters corporativos).

6. CONCLUSÃO

A execução e documentação desta primeira etapa do projeto semestral permitiram à equipe validar na prática a interdependência dos mecanismos de segurança em redes corporativas. A vulnerabilidade crítica exposta no Módulo 1 (onde o acionamento do Modo Promíscuo abriu caminhos para a interceptação passiva de pacotes) encontra as suas contrapartidas e mitigações diretas nas camadas superiores : o Módulo 2 demonstrou como a criptografia híbrida do TLS neutraliza o sniffing ao embaralhar os fluxos de dados de forma célere , e o Módulo 3 evidenciou como os desenvolvedores blindam os identificadores críticos de sessão contra roubos e manipulações através de diretivas de segurança em nível de aplicação. Por fim, o Módulo 4 consolidou o isolamento seguro do tráfego corporativo ao canalizar dados protegidos por algoritmos de integridade e confidencialidade através de túneis criptográficos em ambientes de rede públicos.

As Provas de Conceito realizadas estabelecem a base de segurança necessária para o avanço das próximas etapas do projeto prático semestral.

7. REFERÊNCIAS BIBLIOGRÁFICAS

1. KUROSE, James F.; ROSS, Keith W. **Redes de Computadores e a Internet: uma abordagem top-down**. 7. ed. São Paulo: Pearson Education do Brasil, 2016.
2. STALLINGS, William. **Criptografia e Segurança de Redes: princípios e práticas**. 6. ed. São Paulo: Pearson Education do Brasil, 2015.
3. TANENBAUM, Andrew S.; WETHERALL, David J. **Redes de Computadores**. 5. ed. São Paulo: Pearson, 2011.
4. DOCUMENTAÇÃO TÉCNICA INTERNA. **Projeto Semestral - Parte 1: Conexões Seguras**. Faculdade de Tecnologia SENAI Felix Guisard, 2026.